

Règles d'engagement

TP 1 · Lire une lettre de mission



1 Fenêtre et rythme

- ◆ Fenêtre quotidienne autorisée : 08:30Z à 18:00Z
- ◆ Heure limite d'arrêt quotidien : 18:00Z
- ◆ Aucun test actif avant l'ouverture quotidienne.
- ◆ Aucun test actif après l'heure limite d'arrêt.
- ◆ Toute action hors fenêtre est interdite même si la cible est bonne.

2 Intensité maximale

- ◆ L'intensité maximale autorisée pour un scan léger est moyenne.
- ◆ Une action marquée forte dépasse le plafond de charge.
- ◆ Une action marquée basse reste privilégiée pour les lectures et sondes simples.
- ◆ Les scans portent au plus sur un nombre réduit de ports publics convenus.

3 Actions jamais autorisées

- ◆ ingenierie_sociale
- ◆ force_brute
- ◆ modification_metier
- ◆ dos
- ◆ Toute destruction de données ou tout contournement de validation métier.

4 Actions autorisées dans la limite du périmètre

- ◆ Lecture passive des DNS publics.
- ◆ Lecture des en-têtes HTTP et des certificats publics.
- ◆ Scan léger des ports 80 et 443 sur le bloc public autorisé.
- ◆ Connexion avec un compte de test explicitement livré par le client.

5 Comptes de test et actions authentifiées

- ◆ Toute action authentifiée sur un portail applicatif ou sur le VPN suppose un compte de test déjà livré.
- ◆ Portail et stock disposent d'un compte livré au départ.
- ◆ Paie et VPN restent bloqués tant qu'Ibrahim Sanou n'a pas livré le compte promis.
- ◆ Sans compte livré, la bonne décision consiste à demander le compte et à suspendre l'action.

6 Clarifications juridiques et métier

- ◆ Toute preuve touchant la paie ou des données personnelles sensibles requiert une validation explicite de Rokia Bamba.
- ◆ Une action demandant cette validation entre dans la colonne à clarifier et non dans la colonne autorisée.
- ◆ Une preuve minimale approuvée vaut mieux qu'un export volumineux.

7 Contacts et escalade

- ◆ Contact technique d'urgence : Ibrahim Sanou - directeur informatique du client
- ◆ Contact juridique : Rokia Bamba - responsable juridique du client
- ◆ Cheffe de mission côté prestataire : Mariam Diallo
- ◆ Testeur côté prestataire : Yao Kouassi
- ◆ Canal d'urgence : appel puis confirmation écrite dans le journal de mission

8 Conditions d'arrêt

- ◆ Arrêt immédiat si la disponibilité semble menacée.
- ◆ Arrêt immédiat si une action touche une cible non confiée.
- ◆ Arrêt immédiat si une donnée sensible apparaît au-delà de la preuve minimale convenue.
- ◆ Arrêt immédiat si une charge forte était envisagée par erreur.

9 Rappels de classification

- ◆ Une bonne cible avec une famille jamais autorisée devient interdite.
- ◆ Une bonne cible sans compte livré pour une action authentifiée devient à clarifier.
- ◆ Une cible hors périmètre reste interdite même pour une action passive.
- ◆ Un sous-domaine non écrit dans la lettre doit être clarifié avant toute action.
- ◆ Une action passive n'est jamais une excuse pour toucher un actif tiers.
- ◆ Une clarification obtenue oralement doit être relayée par écrit avant exécution.

10 Exemples de bonne lecture

- ◆ Un scan léger à 10:00Z sur 198.51.100.21 peut entrer dans le cadre.
- ◆ Un scan fort sur la même cible reste interdit par la charge.
- ◆ Une collecte sur paie peut entrer en périmètre tout en restant bloquée par l'absence de compte ou de validation juridique.
- ◆ Une lecture sur un partenaire reste hors mission même si elle semble inoffensive.

11 Règle finale

- ◆ Avant toute action, croise la cible, la famille, l'intensité, l'horaire et les comptes fournis.
- ◆ Si un seul de ces points manque ou contredit les ROE, classe l'action hors autorisation immédiate.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite.